The AI Governance For Startups Playbook

A 24-page field guide to shipping AI products that pass enterprise procurement, survive an EU AI Act audit, and don't get your startup sued.

Who this is for: founders and product leads at AI startups who are tired of "we'll add governance later" and want a practical, opinionated playbook for doing it now without hiring a 12-person legal team.

What this is not: a 400-page textbook on machine learning ethics. This is the minimum viable governance program you can ship in 30 days.

Chapter 1 -- Why governance is a feature, not overhead

Most AI startups treat governance as a tax: something bigcos do to slow down sales cycles. The opposite is true. Done well, governance is the reason your enterprise deal closes in 60 days instead of 9 months. Done badly, it is the reason your seed round doesn't convert to a Series A when the lead investor asks "how do you handle EU AI Act risk?" and you have nothing to show.

The reason: every enterprise buyer, every government RFP, every Series A+ term sheet now asks for evidence of AI governance. They want a model card. They want a risk tier. They want to know where training data came from. They want to know who signed off on the last model release. If your answer to any of these is "we'll get back to you," you lose the deal. If your answer is "here's the doc, here are the test results, here's the change log," you close.

The hard part is that this evidence is hard to fake. You either have the discipline to build it into the development loop, or you don't, and your enterprise pipeline will reflect that within two quarters.

This playbook is about the discipline. Specifically, the minimum viable version of it that holds up to a real audit. The framework underneath is the NIST AI Risk Management Framework (AI RMF 1.0, January 2023) plus the EU AI Act risk tiers -- the two standards that, between them, cover 80% of what enterprise buyers and regulators are going to ask about.

By the end of this book, you will have a 30-day plan to ship a governance program that survives both.

Chapter 2 -- The four artifacts every AI startup must have

You need four documents. Not 40. Four. Every enterprise security review, every AI Act conformity assessment, and every diligence call will pull from these same four files. Build them once, keep them current, and reuse them forever.

1. Model card. One page per model in production. Sections: intended use, out-of-scope use, training data summary, evaluation results (with dates), known limitations, contact. Use the Google model card template.

Update it every time you ship a new version. The buyer wants to see the version history, not just the current state.

2. Risk tier. Each model gets a tier: 1 (minimal risk, internal use only), 2 (limited risk, customer-facing but no automated decisions), 3 (high risk, automated decisions affecting people), or 4 (prohibited under EU AI Act -- do not build). Most startups should have zero tier 3 models and zero tier 4 models. If you have a tier 3, you also need a conformity assessment, which is a 30-page document. Plan accordingly.

3. Data lineage. A spreadsheet or database table: for every model, where did the training data come from, when was it collected, what consent did users give, and how is it deleted on request. This is the single most-failed audit item. If you can't answer "where did the training data for model X come from" in under 30 seconds, you don't have data lineage.

4. Change log. A git-style log of every model release: what changed, who approved, what tests ran, what rollback plan exists. The EU AI Act requires this for tier 3. Enterprise buyers ask for it for everything. A Notion page or a `CHANGELOG.md` in your model repo is fine.

You can have all four in a week. Most startups take a quarter because they overthink the format. Use the templates in Appendix A. Done is better than perfect.

Chapter 3 -- The 30-day plan to ship a governance program

The plan is deliberately small. If you can't do 30 days of this, you can't do governance at all and should not be selling to enterprises.

Week 1 -- Inventory. List every model in production. For each: intended use, who owns it, last training data refresh. You will find 2-3x more models than you thought. That's normal. Half of them are probably internal tools that don't need governance, but you have to list them to know that.

Week 2 -- Risk tier everything. For each model, assign a tier using the EU AI Act + NIST framework (Appendix B). The honest answer is usually: most are tier 1 or 2, two are tier 3, none are tier 4. If you have a tier 3, block two days that week to write the conformity assessment. If you have a tier 4, you have a much bigger problem -- stop and talk to a lawyer.

Week 3 -- Write the four artifacts. One model card per tier 2+ model. One data lineage doc per tier 2+ model. One change log per model. One risk register for the company. This is the boring part. Block 4 hours/day for a week. By Friday you have all four documents.

Week 4 -- Test the program. Pick your largest enterprise prospect. Ask them for their security questionnaire. Fill it out using only the four artifacts. If you can answer 80% of the questions in one afternoon, the program works. If you can't, you have a real gap and you now know what to fix.

The output of week 4 is a real, audit-ready governance program. It will not be perfect. It will be enough.

Chapter 4 -- The five things that will get you in trouble

These are the patterns I've seen get AI startups into actual legal or reputational trouble. They are all preventable.

1. Scraping training data without consent. If your training data came from public web scraping (Common Crawl, etc.), you have a consent problem. The EU AI Act Article 10 requires documentation of data quality and provenance. Some US states (California, Illinois) have biometric and privacy rules that also apply. The fix: switch to licensed datasets, or document the scraping and add an opt-out mechanism.

2. Releasing a model without a rollback plan. Every model release needs a documented rollback. Not a Slack message saying "we can revert if needed" -- an actual procedure: which env vars to flip, how to invalidate the model cache, who has the keys. Without it, when a regulator asks "how do you recall a model?" you have no answer.

3. Letting marketing call the model "fully automated" when it isn't. If a human reviews the model's output before it reaches the user, the marketing page cannot say "no human in the loop." The EU AI Act considers this misleading. The FTC has already issued fines for similar claims. If a human is reviewing, say so. If a human isn't, document the test results that show it doesn't need to be.

4. Collecting feedback data without a deletion path. If you store user feedback to retrain on later, you need a way to delete it on user request. GDPR Article 17, CCPA, and most enterprise contracts all require this. The fix: a `DELETE /users/{id}/data` endpoint that actually deletes from your training data warehouse, not just the production database.

5. Skipping bias testing because "we'll add it later." The bias tests are not optional for tier 2+ models. They are 3-5 days of work, not 3-5 weeks. Pick a framework (Aequitas, Fairlearn, or your own), pick a protected attribute, run the test, document the result. If the test shows bias, document that too and the mitigation plan. Auditors care more about "you tested and found X" than "we have no bias." The former is governance. The latter is a liability.

Chapter 5 -- The governance program that scales

After the 30-day plan, you have the four artifacts and a working process. The next 6 months are about making it a habit, not a one-time project.

Quarter 1 -- Embed the change log. Every model release must include a change log entry. Add it to your CI/CD pipeline as a required field. Reject merges that don't update the change log. This is one PR review rule and it solves 50% of the long-term governance debt.

Quarter 2 -- Quarterly bias audit. Run the bias tests on every tier 2+ model once a quarter. Publish the results internally. The first time you do this you will find a real issue. That is the point. Better you find it than the regulator.

Quarter 3 -- External audit. Hire an external AI governance consultant to review your four artifacts. Cost:

$15-30k. Value: you get a list of gaps and a credibility stamp for enterprise sales. The ROI is one closed deal.

Quarter 4 -- Conformity assessment for tier 3. If you have a tier 3 model, you now need a formal conformity assessment. This is the EU AI Act's required document for high-risk systems. Budget 4-6 weeks. Start in Q4 so it's done by the end of the fiscal year.

By month 12 you have a governance program that holds up to an EU AI Act audit, an enterprise security review, and a Series A diligence call. The cost in time was 30 days of focused work in the first month and one day per month after. The cost in cash was zero unless you hired a consultant, in which case $20-40k. The cost in deals lost from not having it is the part that motivated you to read this book in the first place.

Appendix A -- Templates

- **Model card template:** Google's open-source template at `modelcards.withgoogle.com/about/eval`. Use the short version (1 page).
- **Data lineage template:** A spreadsheet with these columns: model name, dataset name, source, collection date, consent basis, retention period, deletion endpoint.
- **Risk register:** A spreadsheet with: risk ID, description, likelihood, impact, mitigation, owner, review date. Add 5-10 rows the first week.
- **Change log:** A markdown file in each model repo. Format: `## v1.2.3 -- 2026-01-15 -- Added bias test, updated training data`. One entry per release.

Appendix B -- EU AI Act risk tiers (summary)

- **Tier 1 (minimal risk):** spam filters, games, internal tools. No obligations.
- **Tier 2 (limited risk):** chatbots, content recommendation, image generation. Transparency obligations (disclose AI, label outputs).
- **Tier 3 (high risk):** credit scoring, hiring, medical, education, biometric ID, critical infrastructure. Full conformity assessment, data governance, human oversight, accuracy/robustness testing.
- **Tier 4 (prohibited):** social scoring, subliminal manipulation, real-time biometric ID in public spaces (with narrow exceptions). Do not build.

Appendix C -- Resources

- NIST AI RMF 1.0 (free PDF, `nist.gov/itl/ai-risk-management-framework`)
- EU AI Act (full text, `artificialintelligenceact.eu`)
- Google Model Cards (template + paper, `modelcards.withgoogle.com`)
- Fairlearn (open-source bias testing, `fairlearn.org`)
- Aequitas (open-source bias audit, `github.com/dssg/aequitas`)
- The AI Incident Database (`incidentdatabase.ai`) -- see what other companies got wrong

Conclusion

You don't need a 12-person legal team to ship AI governance. You need four documents, 30 days, and the discipline to keep them current. The model card. The risk tier. The data lineage. The change log. The rest is

repetition.

If you ship the 30-day plan and the four artifacts are out of date within 6 months, you didn't really ship a governance program -- you shipped a project. The program is the habit. The habit is one PR review rule and one day per quarter.

Either way, governance is now a buyer expectation, not a nice-to-have. The startups that win enterprise deals in 2026 and beyond are the ones whose founders read a playbook like this on a Tuesday and shipped the program by Friday.

Go ship it.